

TheraVoca — Legal Engagement Brief

Prepared: 2026-05-13

For: Healthcare attorney engagement (digital health / HIPAA / state health privacy)

From: Josh Rose, Founder, TheraVoca LLC — josh@theravoca.com

Purpose: Validate TheraVoca's posture as a consumer-directed marketing platform that is neither a HIPAA Covered Entity nor a Business Associate, and identify any remaining state-law obligations before public launch.

1. The ask, in one paragraph

We are a pre-launch digital-health startup matching patients with outpatient therapists in Idaho. Based on engineering analysis (summarized in this brief) we believe TheraVoca is neither a HIPAA Covered Entity nor a Business Associate. We've architected the product around that posture. **We need a healthcare attorney to validate that classification in writing before we serve our first real patient.** Specifically: a one-page legal opinion confirming (or correcting) the classification, plus review of two short documents (Privacy Notice + Therapist Terms of Use) for consistency with that posture. We are also seeking guidance on state-law obligations that apply regardless of HIPAA status. We expect this to be a 3-8 hour engagement; we are not asking for ongoing counsel at this stage.

2. About TheraVoca

- **What it is:** A web platform where Idaho residents fill out a short, structured intake form describing what they want in a therapist (insurance, modality, presenting issues, preferences). TheraVoca's matching engine ranks Idaho-licensed therapists and emails the patient a shortlist of three matches. The therapist-patient relationship begins (if at all) when the therapist accepts a referral and contacts the patient directly outside TheraVoca.
 - **Where it operates:** Idaho only at launch. Geographic restriction is enforced server-side — non-Idaho intake submissions are rejected before being written to the database.
 - **Who pays:** Patients use TheraVoca free. Therapists pay (subscription model TBD — \$50-150/mo range).
 - **What we do NOT do:** - Render any clinical care, advice, or treatment - Diagnose, prescribe, or interpret symptoms - Bill insurance or transmit any HIPAA-covered transaction (eligibility checks, claims, etc.) - Schedule appointments inside a therapist's EHR or practice management system - Act as a clearinghouse - Hold any therapist out as a TheraVoca employee or partner - Sell or share patient data with advertisers (no third-party tracking pixels)
 - **Closest analogs:** Psychology Today's directory (which takes the same non-CE/non-BA posture). NOT BetterHelp (they pivoted into direct-to-consumer therapy provision; we have not).
-

3. The classification we're asserting

TheraVoca is neither a HIPAA Covered Entity nor a Business Associate.

HIPAA category	Our analysis
Covered Entity — health plan	No. We do not provide or pay for health care.
Covered Entity — healthcare clearinghouse	No. We do not process claims, eligibility, or any standard HIPAA transaction.
Covered Entity — healthcare provider transmitting a HIPAA-covered transaction	No. We do not provide healthcare and do not transmit any HIPAA-covered transaction electronically.
Business Associate of any Covered Entity	We assert no. Patients submit their information directly to TheraVoca as part of their own consumer-directed search for a therapist. We do not handle PHI "on behalf of" any therapist's practice. The therapist-patient relationship — and therefore any HIPAA obligation on the therapist's side — begins only after the therapist accepts a referral and contacts the patient outside the platform.

4. Architectural decisions supporting that classification

We've made deliberate choices in code and product to reinforce the consumer-directed marketing posture. The list below is non-exhaustive; underlying audit docs are in §10.

- **Patient submits directly to TheraVoca.** No therapist or therapist's practice routes intake through us.
- **Idaho-only enforcement is server-side.** Frontend gates by COVERED_STATES; backend independently rejects non-Idaho submissions in the request creation path and audit-logs every rejection. A direct API call cannot bypass.
- **Free-text PHI fields are gated behind explicit consent toggles.** "Prior therapy notes" and "deep-match resonance" are 250-char-capped and only appear in the form if the patient opts in via a checkbox. The checkbox value is persisted alongside the text as auditable proof of consent.
- **Therapist notification emails carry only opaque IDs + a portal link.** They do NOT embed the patient's clinical preferences or presenting issues in the email body. Therapists see clinical information only after logging in.
- **Patient-facing emails carry no PHI in the body either.** All sensitive content is behind one-click HMAC-tokenized portal links.
- **LLM prompt sanitization.** Every prompt sent to our LLM provider (Anthropic) is sanitized to redact emails, phone numbers, and ZIP codes before transmission. Patient emails are HMAC-hashed before any LLM ever sees them.
- **Audit log uses hashed identifiers.** Patient emails are HMAC-SHA256-hashed before being written to the audit log. IP addresses are similarly hashed (same IP -> same hash, but not

reversible). Audit log has a 7-year TTL.

- **No third-party advertising or behavioral-tracking pixels on patient-facing pages.** PostHog session recording is disabled globally. No Meta Pixel, LinkedIn Insight Tag, Google Tag Manager, or similar. Server-side conversion tracking only.
 - **Privacy Notice explicitly states non-CE/non-BA classification with the reasoning.**
 - **Therapist Terms of Use explicitly state TheraVoca is not a Business Associate and does not sign BAAs.** Same posture statement as Psychology Today.
 - **Database hygiene:** Mongo Atlas, TLS-enforced in production (refuses to start with a plaintext URI). Patient PHI never traverses the network in plaintext.
 - **Auth hygiene:** Bearer-JWT sessions (not cookies, so no CSRF surface), bcrypt for stored passwords, 8h admin session TTL, login lockout, constant-time admin password compare, minimum JWT-secret entropy enforced.
-

5. Specific questions for the attorney

These are sourced from our scope-out audit (§10), refined for clarity:

1. **Is TheraVoca's classification as neither Covered Entity nor Business Associate correct under HIPAA, given the architectural facts in §4?**
2. **Is Idaho's status as the only operating state material to the analysis, or is the classification jurisdiction-independent?**
3. **Does Washington's My Health My Data Act (MHMDA) reach TheraVoca even though we serve only Idaho residents today? (We expect not, since we'd never collect a WA resident's data, but want this confirmed.)** Same question for California's CMIA / SB-1223, Texas HB-300, Connecticut CDPa, Nevada SB370 — each contingent on us expanding to those states.
4. **Is the FTC Health Breach Notification Rule (HBNR) in scope for us?** Our reading is yes (the 2024 expansion sweeps in non-HIPAA health apps that "draw" data from multiple sources). We've written a breach-notification runbook on that assumption.
5. **Are there state laws or professional regulations specific to Idaho that we should be aware of beyond the federal posture?** (Idaho Patient Act? Idaho Board of Counselor licensing rules touching marketing or referral services? Mental-health-specific advertising rules?)
6. **Is the one-line "we are not your Business Associate" disclaimer in the Therapist Terms (§10) sufficient, or do we need explicit written acknowledgment from each therapist on signup?** (We can wire an "I agree" checkbox into the therapist signup flow if needed.)
7. **Risk of architectural drift:** If a therapist accepts a referral and the patient never books a session with that therapist, does TheraVoca retain any residual Business-Associate-like relationship for the data it shared with the therapist? Or does the marketing-handoff posture cleanly terminate?
8. **Do you see any architectural changes we should make to strengthen the non-CE/non-BA position?** (Specifically: scope-out audit Section 3 recommends splitting the

patient request into two physically separated collections — identity vs. clinical preferences — joined only by an opaque UUID. We have not done this, deferring on your input. Is it material?)

6. State-law inventory we want validated

We've already done the following based on engineering reading of state laws. Please confirm or correct:

- **Idaho consumer-protection / breach-notification (Idaho Code § 28-51-104 et seq.):** In scope; runbook written.
 - **FTC Act Section 5:** In scope; Privacy Notice claims are limited to things we actually do.
 - **FTC Health Breach Notification Rule:** Assumed in scope (60-day notification clock).
 - **MHMDA, CMIA, CDPA, SB370, HB-300:** Out of scope today (Idaho-only); will be in scope on expansion.
-

7. Documents we'd like reviewed

These are short and load-bearing. Reviewing them for consistency with the asserted posture is part of the engagement we're requesting:

1. **Privacy Notice** — includes the explicit non-CE/non-BA section. File: `frontend/src/pages/PrivacyNotice.jsx`.
2. **Therapist Terms of Use (draft)** — includes the non-BA disclaimer, posted with a "draft pending counsel review" banner. File: `frontend/src/pages/TherapistTerms.jsx`.
3. **Patient Terms of Use** — already live, last updated 2025-04-23. Probably needs a light refresh to match the current posture. File: `frontend/src/pages/TermsOfUse.jsx`.

(We can send these as PDFs or as a link to a staging environment, whichever you prefer.)

8. Deliverables we're asking for

Order of priority:

1. **Written legal opinion (1-2 pages)** confirming or correcting the non-CE/non-BA classification, with reasoning. This is the document we will show investors, enterprise therapist customers, and (if it ever comes to it) regulators.
2. **Targeted edits to the Therapist Terms of Use** so we can remove the "draft pending counsel review" banner and adopt the document as final.
3. **Light pass over the Privacy Notice** for consistency.
4. **Short list of state-law obligations** we should be aware of in Idaho beyond what's in §6.
5. **Optional:** ongoing relationship for HIPAA / state-law questions on a retainer or hourly basis.

We do **not** expect a full enterprise-grade HIPAA compliance program — that's the parallel path we've explicitly chosen not to take (vendor BAAs, AWS migration, etc., would all be in scope if you tell us our classification is wrong).

9. Logistics

- **Entity:** TheraVoca LLC (Idaho LLC, in formation / formed — TBD confirm)
 - **Founder / signatory:** Josh Rose, sole owner today
 - **Timeline:** We are targeting launch within roughly 4-8 weeks. The legal opinion is on the critical path — the sooner the better. Happy to schedule a 60-minute kickoff call to walk through the architecture in person if helpful.
 - **Engagement budget:** Open to flat-fee or hourly. Rough estimate from our research is \$3-5K for the scope above; we'll discuss.
 - **Communication preference:** Email primary (josh@theravoca.com). Phone OK for kickoff and questions.
 - **What we'd love:** an attorney with prior experience in mental-health-adjacent digital-health (Psychology Today / Zocdoc / BetterHelp / Talkspace-adjacent). If you have not done this exact vertical before but have done HIPAA-compliance work in adjacent verticals (e.g., telehealth, wellness apps), that's also great — the model is close to Psychology Today's directory architecture, not to BetterHelp's direct-care model.
-

10. Reference documents we can share on request

These are internal audit docs we've prepared. They are engineering-grade, not legal opinions — the whole point of this engagement is to get a real legal opinion. Happy to send any of these:

Doc	Contents
HIPAA Scope-Out Audit (HIPAA-SCOPE-OUT-2026-05-13.md)	The full reasoning behind the non-CE/non-BA classification we're asserting. Includes our open questions for counsel (this brief's §5 is sourced from there).
HIPAA Audit — Compliance Path (HIPAA-AUDIT-2026-05-13.md)	The alternative scenario where we DON'T scope out and instead pursue full BAA / hosting compliance. Kept for reference; not the path we're pursuing.
Breach Notification Runbook (RUNBOOK-BREACH-NOTIFICATION.md)	Operational runbook covering FTC HBNR + Idaho + multi-state forward-looking table. We'd value your review of this too.
Privacy Notice (PrivacyNotice.jsx)	Live, with the non-CE/non-BA section.
Therapist Terms of Use draft (TherapistTerms.jsx)	Draft with non-BA disclaimer, banner notes "pending counsel review."
Patient Terms of Use (TermsOfUse.jsx)	Live, originally drafted 2025-04, possibly needs refresh.

11. What we are NOT asking

To keep scope crisp:

- We are NOT asking for a SOC 2 / HITRUST assessment.
- We are NOT asking for full HIPAA-compliance-program build-out (Privacy Officer designation, full risk analysis, vendor BAA paperwork, employee training, etc.) — that's the path we are deliberately avoiding by adopting the scope-out posture.
- We are NOT asking for advice on Idaho LLC corporate structure, IP, or trademark.
- We are NOT asking for employment / contractor advice.
- We are NOT asking for marketing-claim review at large — only the legal-posture claims in the Privacy Notice and Therapist Terms.

If the legal opinion (§8, item 1) reveals that our classification is wrong, we may then expand scope to include vendor BAA paperwork and hosting migration counsel. That's the explicit fork in the road.

End of brief. Thank you for considering the engagement.